

ORAVONT SYSTEMS

Underwater Acoustic Intelligence

Re-ID Administrator Security Note

Applies to: disc5-reid v1.1 and later · **Hold with:** system administration documentation, not the general User Manual

This note covers the one topic deliberately kept out of the *Re-ID User Manual*: the security model of the sign-in system, its limits, and recovery when the Admin password is lost. Everything operational — installation, creating accounts, the activity log, upgrades — is in the User Manual, Parts II–III.

1. What the sign-in protects, and what it does not

The sign-in provides **accountability, not access control**. It puts a name against every action and keeps destructive functions away from accidental use. It is **not** a security boundary against anyone with access to the Windows account: accounts are held in an ordinary file (`users.json`) beside the executable, and anyone at the machine can read, edit or delete that file like any other. **Physical control of the PC and of the Windows account remains the real security control**, and the sign-in should be briefed that way.

Passwords are stored scrypt-hashed — no user, including the Admin, can read another's password from the file.

2. Recovery from a lost Admin password

There is no reset channel on an air-gapped machine and no back door in the application. The available route is to discard the account set: **deleting `users.json` returns the application to first-run setup**, where a new first Admin is created.

Consequences: **all accounts are lost** and must be re-created; the **gallery is untouched** (`gallery.npz`, `gallery_tonal.json`); the **activity log is untouched** and keeps appending.

Because this route is open to anyone at the machine, its control is visibility, not difficulty: the log is a separate file from the accounts, so a reset shows as a gap followed by a fresh `bootstrap_admin` event — the tell-tale to look for when reviewing the log. Maintaining a **second enabled Admin account** is the cheap insurance that makes this procedure unnecessary; the application itself refuses to remove the last enabled Admin.

3. Why the password policy is what it is

Defaults: minimum 8 characters, no complexity rules, no expiry (5 failed attempts → 5-minute lockout; 20-minute idle timeout). Expiry is deliberately off: on a machine where every user can reach the account file anyway, forced rotation adds burden without adding protection, and measurably degrades the quality of the passwords people choose. Complexity and expiry, if mandated later, are configuration changes, not redesigns.